

Cyber Security - Cyber Incident Response Plan

Table of Contents

Table of Contents.....	1
Introduction.....	2
Scope	2
Purpose	2
Principles	3
Methodology.....	3
1. Preparation Phase.....	4
2. Identification Phase.....	4
Identification System – Priority Rating.....	5
Incident Ranking	6
Critical Level Incidents - Priority-1.....	6
High Level Incidents - Priority-2	7
Moderate Incidents – Priority-3.....	7
Low Ranking Incidents – Priority-4.....	8
3. Containment Phase.....	8
4. Eradication Phase.....	10
5. Recovery Phase.....	10
6. Lessons Learned Phase.....	11
Cyber Incident Response Team (CIRT).....	11
Core Team	11
Secondary Team Members (as required)	12
Team Objectives.....	12
Team Responsibilities	12
Incident or Threat Enforcement	13
Employee Incident Involvement	13
External Incident Involvement.....	13
Unintentional Incident Involvement.....	13
Supporting Documentation	13
Review	13

Introduction

It is critical for APM to have an effective Cyber Incident Response Plan (CIRP) addressing security incidents. This plan, combined with a well-trained Cyber Incident Response Team (CIRT), can recover from an adverse event, resuming business operations and supporting regulatory or legal actions. This response plan aims to support a series of common undertakings:

- Identifying security incidents;
- Resolving an incident quickly;
- Protecting assets and reducing losses;
- Recovering from a security event;
- Mitigating future organisational risks or exposures;
- Reducing the chaos of crises;
- Proper and consistent documentation.

To be an effective tool, the CIRP must address not only IT systems and process but also incorporate the many aspects of APM's business operations in managing an incident response. Through common "Best Practices and NIST Guidance" the plan assigns each event a degree of urgency by priority ranking which defines an action plan associated with risk and initiates specific response teams, technologies, and business groups.

Scope

APM's CIRP represents a formalisation and standardisation of current operational practices of rating and defining the approved processes, procedures, and guidelines for a CIRT to follow. These processes and procedures are designed to mitigate risks, reduce costs, and reduce downtime due to a security incident or catastrophic event.

This CIRP applies to all APM information systems, operational data, networks and any person or device that gains access to these systems and data that fall within the control of APM.

Cyber security incidents include, but are not limited to:

- A violation of APM computer security policies and standards;
- Unauthorised computer access;
- Loss of information confidentiality; loss of information availability; compromise of information integrity;

A denial-of-service condition against data, network or device;

- Misuse of service, systems of information; or
- Physical or logical damage to systems.

This document does not contain technically detailed "how to" information, APM's IT Team understand the complexity of their positions and the systems they are supporting. Instead, the plan provides a practical road map of what to do during such undesired events.

Purpose

The purpose of this CIRP is to outline a set of response requirements that are pre-approved ensuring cyber security, business operations, training, and regulatory compliance obligations are adhered to with the primary goals of protecting APM's assets, including data, people, clients and data and resuming normal operations as quickly as possible.

The goal of the CIRP is to guide:

- the detection of cyber security incidents;

- determination of their scope and risk, through a standardised rating system;
- appropriate response to the incident;
- communication of the results and risks to all stakeholders; and

reduction of the likelihood of the incident recurring through continually reviewing the plan and incorporating lessons learned.

Executing the plan in a structured manner will limit impact, increase the confidence of external stakeholders, and reduce recovery time and costs.

Principles

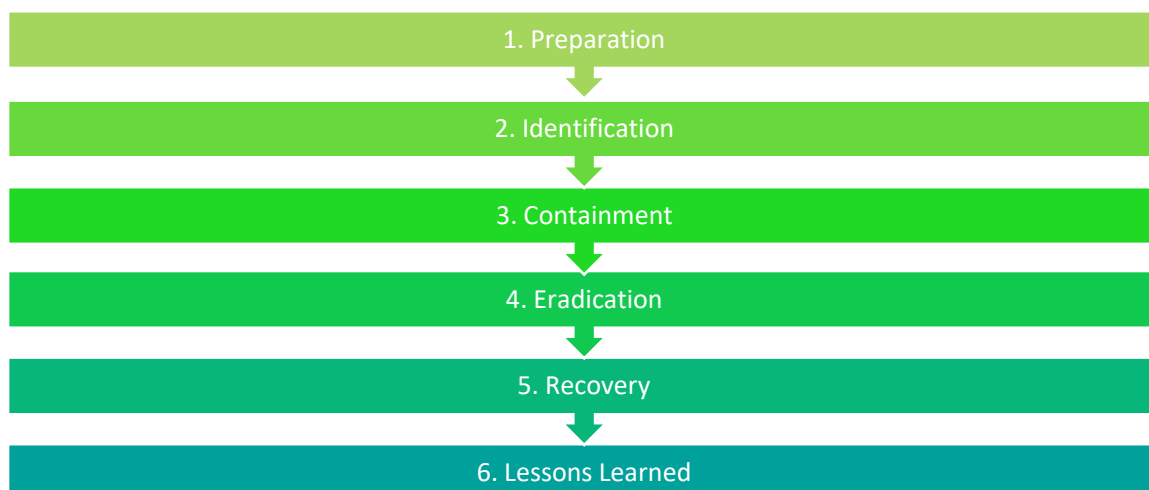
APM's CIRP takes as its foundation the following principles:

- **Risk-based approach:** cyber security incidents are low likelihood / high consequence risks. Because of the potential impact of such an incident, a 'worst case' approach needs to be adopted in the first instance, until conflicting evidence is confirmed. As such, in the event of, for example, a data spill, the incident will be managed on the assumption that information has been compromised;
- **Continual Improvement:** The APM CIRP will be a living document which is operationalised, regularly tested and continually reviewed and improved to maintain its currency, relevance and effectiveness;
- **Integration:** APM's CIRP is integrated across the IT Team and the ES Business Unit to ensure a coordinated, integrated approach to cyber incident management and avoid information silos and duplication of effort;
- **Delegation:** in the event of a confirmed cyber security incident, the CIRT Manager is delegated the authority to take whatever actions are necessary to immediately contain the incident and limit damage / loss. While the CIRT Manager will maintain communication and information with Executive Management, s/he will not be required to wait for Executive approval to act. For this reason, the CIRT Manager will be effectively trained in incident response and remediation;
- **Communication & awareness:** All relevant staff will be made aware of the process of reporting potential and actual cyber security incidents in a timely manner.

Methodology

The methodology for this CIRP reflects the current design and "Best Practices" of National Institute of Standards and Technology Publications NIST 800-53, NIST 800-61 and the NIST 800-83.

The CIRP creates six (6) individual operating elements, which have been defined by regulatory groups, compliance laws and law enforcement.



1. Preparation Phase

Regardless of the cause of the incident, preparation is the most crucial phase compared to all others, as it will determine how well the CIRT will be able to respond in the event of a crisis.

Preparation includes those activities that enable the CIRT to respond to an incident: policies, tools, procedures, effective governance and communication plans. Preparation also implies that the CIRT have instituted the controls necessary to recover and continue operations after an incident is discovered. Post-mortem analyses from prior incidents should form part of the continuous improvement of this stage.

Requirements:

- Define CIRT roles and responsibilities as they apply to each incident;
- Processes and procedures;
- Have the required security tools available combined with effective training;
- Complete regular testing of the Incident Response Plan, at least annually.

Case Management

This is the accumulation of the incident's information, the forensic data, evidence, chain of custody, the people involved, incident register and incident summations from the various team members. This information is the instrument supporting lawsuits or protecting the organisation from regulatory legal actions. The Case Management phase is also critically important in providing information to be utilised in the management of future information security incidents and risks.

One of the major differences between an incident file and case management file is information that is highly confidential, such as names and addresses, exterior involvements, legal authorities combined with legal documentation and case opinions, will be included in the case management file.

- Low - Incident Response files are required to be stored for 1 year
- All other Incident Response files are stored as per Legal Teams requirements.

2. Identification Phase

Detection

Detection is the discovery of the event with security tools or notification by an inside or outside party about a suspected incident.

Attack Vectors

Incidents can occur in countless ways, so it is not reasonable to expect this plan to document a response for each incident type. Instead, APM has focussed its efforts on preparation for handling incidents that use common attack vectors including:

- **Attrition:** An attack that employs brute force methods to compromise, degrade or destroy systems, networks or services, e.g. a DDOS intended to deny access to a service or application; a brute force attack against an authentication mechanism, such as passwords, CAPTCHAS, or digital signature);
- **Web:** An attack executed from a website or web-based application, e.g. a cross-site scripting attack used to steal credentials or a redirect to a site that exploits a browser vulnerability and install malware;
- **Email:** An attack executed via an email message or attachment, e.g. exploit code disguised as an attached document or a link to malicious website in the body of an email;

- **Impersonation:** An attack involving replacement of something benign with something malicious, e.g. spoofing, man in the middle attacks, rogue wireless access points and SQL injection attacks all involve impersonation;
- **Improper Usage:** Any incident resulting from violation of APM's *Information Security Code of Practice* (Acceptable Use Policy) by an authorised user, excluding the above categories, e.g. a user installs file sharing software leading to the loss of client personal information, or a user performs illegal activities on a system;
- **Loss or theft of equipment:** loss of theft of a computing device or media used by APM, e.g. laptop, smartphone or authentication token;
- **Inadvertent or Malicious Data Leakage:** through user error, failure to follow correct process or malicious intent, staff may leak data through email, instant messaging, text / SMS, MFDs or hard copy media.

Reporting

All suspected or confirmed cyber security incidents are subject to a reporting requirement. All staff who identify a real of potential incident must immediately report the incident using APM Assist. The Incident Manager will use the on-line version of the Major Cyber Security Incident Register to record the details of the incident. Upon receipt of the Incident Report, the Incident Manager will immediately notify the Chief Information Security Officer (CISO) of the incident to ensure a swift response is affected.

Identification System – Priority Rating

There are a variety of ways that the CIRT could become aware of, for example, a malicious infiltration, such as a user calling the IT Help Desk with a frozen workstation, a Systems Analyst noticing that an application is malfunctioning with no legitimate cause, or a public entity notifying APM that there is an issue with a public-facing system. The Incident Manager becomes aware of a potential cyber security incident must use the following rating scale to determine the Priority.

All incidents will be logged in a Service Now (SNOW) ticket with a Teams War Room created as required. For Priority 1 and Priority 2 incidents, the Major Cyber Security Incident Register should be updated.

The Priority Score will be used to determine the incident's importance relative to other work being performed by CIRT members.

Severity	SLA	Description	Typical Response
Priority-1	Initiate response immediately – Out of Hours included	Critical system failure preventing multiple customers from accessing services beyond acceptable downtime or widespread exposure of sensitive customer data	• Create SNOW ticket • Notify/invoke responsibilities for all stakeholders • Establish Crisis Management Team for external communications • Teams War room stood up for communication and logging • Google Workspace is available should out of band communication be required

Priority-2	During business hours – Response within 15min Out of hours – on-call best effort	Suspected exploitation of security misconfiguration/vulnerability or exposure of sensitive customer data or sweeping malware infection involving multiple hosts	• Create SNOW ticket • Notify/invoke responsibilities for internal stakeholders • Monitor for potential escalation to P-1 • Teams War room if required - after clearance by CIRT Manager
Priority-3	Within 1 hour	Issues preventing one or more customers from utilizing services or security misconfiguration without evidence of exploitation or commodity malware isolated to a single host/endpoint	• Create SNOW ticket • Monitor for potential escalation to P-2 • Teams War room if required - after clearance by CIRT Manager
Priority-4	Best effort within same business day	Issues requiring triage (not immediate attention)	• Create SNOW ticket • Monitor status; escalate if not assigned within reasonable amount of time • No war room required

Incident Ranking

The basis of rating systems includes the following rating criteria:

1. The incident's risk exposure to APM;
2. Possible damage;
3. Chance of threat obtaining privileged access;
4. Extent the threat is active;
5. The recovery aspects;
6. Safety of APM assets and data;

Critical Level Incidents - Priority-1

A **critical** level incident is where there is a known event impacting the confidentiality, integrity, or availability of APM's systems or networks that could be expected to have a severe or catastrophic adverse effect on organisational operations, organisational assets, data or individuals. A severe or catastrophic adverse effect means that, for example, the loss of confidentiality, integrity, or availability might:

- Result in real or potential harm to individuals as a consequence of leakage of personal / sensitive information;

Cause a severe degradation in, or loss of operational capability to an extent and duration that the organisation is not able to perform one or more of its primary functions;

- Result in major damage to organisational assets;
- Result in Significant brand reputation damage or share price impact;
- Result in major financial loss.

APM uses the following as guidelines when defining a critical impact incident:

- Reputation – when the impact results in negative impact on APM reputation on a national or international scale;
- Incidents involving systems classified as *Confidential or Restricted* are more likely to result in a high impact when considering confidentiality and availability.

High Level Incidents - Priority-2

A **high** level incident is where there is a suspected event impacting the confidentiality, integrity, or availability of APM's systems or networks that could be expected to have a severe or catastrophic adverse effect on organisational operations, organisational assets, data or individuals. A severe or catastrophic adverse effect means that, for example, the loss of confidentiality, integrity, or availability might:

- Result in real or potential harm to individuals as a consequence of leakage of personal / sensitive information;

Cause a severe degradation in, or loss of operational capability to an extent and duration that the organisation is not able to perform one or more of its primary functions;

- Result in major damage to organisational assets;
- Result in Significant brand reputation damage or share price impact;
- Result in major financial loss.

APM uses the following as guidelines when defining a high impact incident:

- Reputation – when the impact results in negative impact on APM reputation on a national or international scale;
- Incidents involving systems classified as *Confidential or Restricted* are more likely to result in a high impact when considering confidentiality and availability.

Moderate Incidents – Priority-3

The potential impact is **moderate** if the loss of confidentiality, integrity, or availability could be expected to have a serious adverse effect on organisational operations, organisational assets, or individuals. A serious adverse effect means that, for example, the loss of confidentiality, integrity, or availability might:

- Cause a significant degradation in operational capability to an extent and duration that the organisation is able to perform its primary functions, but the effectiveness of the functions is significantly reduced;
- Result in significant damage to organisational assets;
- Result in significant financial loss.

APM uses the following as guidelines when defining a medium impact incident:

- Reputation – when the impact results in a negative impact on APM's reputation on a local scale;
- Incidents involving systems classified as *Internal* are more likely to result in a moderate impact when considering confidentiality and availability.

Low Ranking Incidents – Priority-4

The potential impact is **low** if the loss of confidentiality, integrity, or availability could be expected to have a limited adverse effect on organisational operations, organisational assets, or individuals. A limited adverse effect means that, for example, the loss of confidentiality, integrity, or availability might:

- Cause a degradation in operational capability to an extent and duration that the organisation is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced;
- Result in minor damage to organisational assets;
- Result in minor financial loss.

APM uses the following as guidelines when defining a low impact incident:

- Reputation – when the impact has a nominal impact on the organisation's reputation;

Security events for a potential incident that has been detected and mitigated by Security tooling. The event has been resolved; however, the Security team should still review and ensure that there is no further risk to the business.

-

3. Containment Phase

CIRT Activation

Once the CIRT Manager has been advised of an incident by a member of staff, s/he will decide as to whether to activate the CIRT. Once the decision is made to activate the CIRT and formally declare an incident, the following process will be implemented:

1. CIRT is to formally assume control of the situation and investigate the threat and its severity based on the Initial Incident Report and Priority Rating;
2. In investigating the threat, the CIRT is to specifically identify which resources / assets are at risk, both internal and external, and which harmful processes are currently running on resources / assets that have been identified as 'at risk';
3. Review all available investigation data and decide as to whether the resources / assets at risk require physical or logical isolation or removal. Resources / assets which pose a significant threat to the continuity of operations are to be immediately isolated / removed, either physically or logically;
4. Should the primary environment for communication and collaboration (Azure) become untrusted or unavailable for any reason, the CIRT Manager may opt to move all communications to the Google Workspace environment. This would allow the Security team and key stakeholders to continue to communicate and collaborate in a secure manner.
5. APM will always take the approach of prioritising containment of an incident over the collecting further evidence unless instructed by law enforcement;
6. Decide containment / isolation strategy – refer to the appropriate Promapp document for containment process;
7. Preserve forensic data referencing the "Incident Response Chain of Custody Process" Promapp process;
8. To all extent possible, all remediation activities should take place on a separate system to the compromised system;
9. Notify stakeholders – if the incident has affected the environment holding personal / sensitive data, i.e. Pulse, in a way that has impacted the system components within this environment, the CIRT Manager will, in conjunction with the Data Owner, notify the Department, as the Accreditation Authority as soon as possible after the identification of the incident by emailing securitycompliancesupport@jobs.gov.au. The CIRT Manager will also notify the Australian Signals Directorate (ASD), seeking their assistance in managing the incident. In these circumstances, the CIRT Manager will instruct the ITSA and all other relevant staff to take no action which could affect the integrity of the evidence prior to ASD's involvement, where the data / system affected is within the remit of the accrediting authority; (915c).

Broad communications – advise affected staff of a potential outage so that interim manual processes can be implemented;

10. Notify authorities – if the incident has, in any way, resulted in a criminal matter that may be readily identified, the CIRT Manager will liaise with the Crisis Management Team to coordinate communication with law enforcement
11. Notify customers – if the incident has, in any way, resulted in the loss of customer data, the CSIRT Manager will liaise with Legal, Privacy and relevant Business Units to coordinate communication with the affected customers. If the incident has not resulted in the loss of customer data, Legal, Privacy and relevant Business Units may still be required to coordinate communication of the incident to customers depending on the scenario and their processes.
12. Conduct a comprehensive root cause analysis of all evidence from investigation including system documentation such as logs, audit trails, rule sets, configuration and hardening standards;
13. If warranted, engage a third-party resource for assisting in the investigation of the incident.

Containment

When an incident has been detected and analysed, it is essential to contain and or isolate the incident as soon as possible before more information or assets are lost, or the anomaly spreads, overwhelming resources. Time is often critical. However, forensic information must be preserved and the call for containment must be made by a subject matter expert within the CIRT.

Typical containment decisions might be:

- Physical or logical shutdown / removal / isolation of affected assets including:
 - All IP addresses in use;
 - Firewalls;
 - Routers and switches;
 - Intrusion Detection Systems (IDS) / Intrusion Prevention Systems (IPS);
 - ES application – Pulse;
 - Remote access;
 - Wireless networks;
 - Servers: Authentication, Web, Proxy, File, Email, DNS, Database and application servers

In so doing, consideration must be given to the risk of losing forensic data / significant down time for business operations;

- Shut down a complete network segment – risk losing forensic data / significant down time for business operations;
- Re-boot the system or systems – risk losing forensic data;
- Disconnect the system(s) from a wired or wireless network;
- Disable certain, non-essential functions;
- Firewall changes to isolate the impacted area.

Containment strategies vary based on the type of incident and the risks involved. For example, the overall strategy for containing an email-borne virus infection is quite different from that of a network-based Trojan-Horse infection or a direct intrusion. Therefore, separate containment strategies have to be tailored for each specific incident. Therefore, separate containment strategies must be tailored for each specific incident. See the appendices to this document for circumstance specific containment information.

Containment and mitigation in both the short term and the long term are key factors in further eradication and mitigation strategies. Long-term containment strategies entail a comprehensive forensic investigation, understanding the incident's make-up and design and a strategy for resuming business operations safely, combined with a full review of back up and data storage reservoirs to understand if the anomaly migrated to storage.

Retaining evidence

For all incident types, all potential evidence that may lead to the root cause of the incident and any remedial action taken must be preserved for later forensic investigation. This may include preserving back up tapes, retaining network traffic logs for a period of seven days prior to the discovery of the incident and preserving artefacts, e.g. emails.

Any retention or removal of potential evidence should be logged in the chain of custody document.

Reference the "Incident Response Chain of Custody Process" Promapp process.

4. Eradication Phase

Eradication and remediation is the post-incident repair of affected systems, communication and instruction to affected parties, and analysis that confirms that the threat has been contained.

To increase the likelihood of intrusion remediation activities successfully removing an adversary from their system, APM will take preventative measures to ensure the adversary has limited forewarning and awareness of planned intrusion remediation activities. Specifically, use of an alternative system to plan and coordinate intrusion remediation activities if they have already compromised email, messaging or collaboration services.

In addition, intrusion remediation activities will be conducted in a coordinated manner during the same planned outage to prevent alerting the adversary, thereby depriving them of sufficient time to establish alternative access points or persistence methods on the system.

After an incident has been contained, eradication is necessary to eliminate components of the incident, such as deleting malicious code, disabling breached user accounts or in the case of an intrusion, closing the access path.

Many system born viruses, Trojan-Horses, worms and malicious code events will require an eradication effort such as:

- Restoring systems from clean and non-infected backup;
- Rebuilding systems from scratch;
- Replacing compromised files with clean versions;
- Installing patches;
- Changing passwords;
- Changing the firewall rule sets;
- Purging memory or registry files;
- Wiping of infected hard disks;
- Review and tightening network perimeter security;
- Review and imposing higher levels of system logging and auditing;
- Ensure backup systems and media are clean;
- 'All clear' communications

5. Recovery Phase

The goal of this phase is to put impacted systems back into production in a safe and secure manner as quickly as possible. This means that the system or systems need to be cleaned, tested and verified by the CIRT and approved for operation by a subject matter expert from within the CIRT and the CISO.

Requirements

- Follow the Disaster Recovery and Business Continuity Plans;
- Document team's actions;
- Review and ensure backups are clean;
- Restore user files/data from backups;
- Where possible, all remediation to take place during the same planned outage;
- 'All clear' communications.

6. Lessons Learned Phase

This is the point at which the system is restored to its normal operating condition. Eradication and recovery have been tested and approved and required software patches have been installed, operational changes have been made through Change Control practices and documented.

It is the responsibility of the CIRT Manager to pull together all the documentation and evidence about the incident and create a Post Incident Report. The draft should contain the artefacts of what occurred during the incident and the remediation processes. Once this report has been created, the CIRT Manager will formally review the information with those that were impacted and participated in handling the incident.

The review will consist of verifying what occurred and discussions about:

- What happened?
- How did it happen?
- Losses or impacted data?
- How can APM mitigate the risk of a reoccurrence?
- What did the CIRT do right?
- How could the CIRT improve?

The CIRT Manager will then compile and submit the final report. Ideally, this will all occur within seven (7) days of an incident.

Cyber Incident Response Team (CIRT)

The Cyber Incident Response Team (CIRT) consists of a Core Team with a Secondary Team to be called if necessary. Each member of the Primary Team will designate an alternate member to participate if the Primary Member is unavailable. The Primary Team will consist of representatives from the following areas:

Core Team

- CISO
- CIRT Manager
- Subject Matter Experts
- Cyber Incident Response Team (CIRT):
 - Global Threat Lead
 - APM's Security Analyst and Security Engineers
 - Security Operations Centre (Quorum Cyber) (if required)
 - Application Manager/s (if required)
 - IT Operations Manager (if required)
 - IT Infrastructure Lead (if required)

Secondary Team Members (as required)

The circumstances surrounding each incident will differ and require personnel with expertise or skills beyond that of the Primary Team. Members of the Primary Team will determine what, if any, additional resources are required, and a Secondary Team may be established with:

- Individuals with decision-making authority identified to have a vested interest in the resolution of the incident, e.g. Global CIO, Group CFO, Business Unit General Managers, Business Unit CEOs;
- Individuals identified as subject matter experts or having skills required for resolution of the incident, e.g. Manager Group Data Privacy, Group General Counsel, Chief Risk Officer;
- Business Relationship Managers representing an affected Client or 3rd Party, such as vendor, may be requested to serve on the Secondary Team.

Team Objectives

The CIRT reports directly to the CIRT Manager. Their combined objective is to:

- Coordinate and oversee the response to incident(s) in accordance with the requirements of APM policies, APM's CIRP, compliance and contract requirements, and State and Commonwealth legislation;
- Minimise the potential negative impact to clients, staff and systems as a result of such incidents;
- Where appropriate, inform the affected stakeholder(s) of action that is recommended or required on their behalf;
- Restore services to a normalised and secure state of operation;
- Provide clear and timely communication to all interested parties.

Team Responsibilities

To ensure an appropriate and timely execution of the CIRT Manager's directions:

- Confirmation of an incident requiring the activation of the team
- Confirmation activities include but are not limited to:
 - Direct conversation with person reporting the incident;
 - Communications with the CISO
 - Communications with the D&T Service Desk;
 - Communications with the relevant Business Stakeholders;
 - Communication with CIRT members or others having information about the event
 - Updating Crisis Management Team about the incident
 - A consistent, timely and appropriate response to an incident;
 - Provide appropriate communication to parties having a vested interest in the incident;
 - Conduct a Lessons Learned Review
 - Maintain the procedures contained in this plan

Incident or Threat Enforcement

Employee Incident Involvement

If an employee is identified as the source of an incident it is essential to notify Human Resources (HR) as soon as possible. The CIRT will provide information and recommendations to HR.

External Incident Involvement

In the case of an external threat, the escalation process should be handled by CIRT Manager-CISO or delegate and possibly In-House Legal Counsel. If required and approved by the CISO, In-House Legal Counsel will respond by taking appropriate action(s) to identify, apprehend, and seek prosecution of the person(s) responsible.

Unintentional Incident Involvement

Many incidents are the result of a lack of training and awareness, a first responder (IT Help Desk) can coach the user on the spot. It is often helpful to contact the relevant Business / State Manager / Team Leader to inform them of the incident. This may help identify re-occurring issues and identify training needs. The CIRT Manager may recommend escalation procedures.

Supporting Documentation

The below documents are expected to be utilised in the event of an Incident Response are available on the APM network in the GLB CORP IT Security Team Incident Response folder or in the Incident Response Drive of the Emergency Google Workspace environment.

- Incident Communication Process
- CIRT Incident Handler Checklist
- TEMPLATE-Incident_EventLog
- IR RACI Matrix Template
- Information Technology - Cyber Security Major Incident Contact List
- Supporting Playbooks
 - Ransomware
 - Phishing / Malicious Link Click
 - Data Breach / Leak / Spill
 - Malware Infection
 - Distributed Denial of Service (DDoS) Attack
 - Theft / Loss of IT Asset
- Chain of Custody Tracking Form

Review

Update this standard whenever requirements change and review at least once a year.